

LLMs in Cybersecurity:

A breakdown of current performance, applications, and governance.

Ari Cooper, Ryan Tran, John Winborne

Cryptography Final Report

June 6, 2026

Abstract

Large Language Models (LLMs) are rapidly transforming the cybersecurity landscape by enabling both unprecedented advances in defensive capabilities and equally powerful avenues for offensive misuse. This paper examines the dual-use nature of LLMs through three interconnected lenses: (1) the technical performance of frontier models in Capture-the-Flag (CTF) environments, (2) the implications of LLM-driven cybersecurity workflows within government agencies such as the Department of Homeland Security (DHS), and (3) a synthesis of emerging governance frameworks that aim to manage the risks of high-capability models. We survey recent research demonstrating LLM proficiency in structured cybersecurity tasks, including knowledge benchmarks (CTF-Know), autonomous exploitation frameworks (CTFAgent), and advanced threat-detection pipelines. We then contextualize these capabilities within real-world governmental AI deployments and analyze associated risks, including data exposure, hallucination, operational misalignment, and adversarial misuse. Finally, we integrate findings from contemporary governance literature to propose a multi-layered strategy for responsibly leveraging LLMs while mitigating dual-use harms. Through this combined technical and policy perspective, the paper outlines how society may balance innovation, security, and ethical stewardship as LLMs become embedded across digital infrastructure.

Introduction

Cybersecurity is undergoing a profound transition as Large Language Models (LLMs) become increasingly capable of performing complex analytical, generative, and reasoning tasks traditionally reserved for human experts. These models now support workflows across

penetration testing, incident response, malware analysis, and threat intelligence, while simultaneously lowering the barrier of entry for adversaries seeking to scale phishing, exploit development, or automated reconnaissance. The resulting dynamic is inherently dual-use: defenders benefit from enhanced automation and situational awareness, but attackers gain access to the same capabilities, creating a rapidly evolving threat surface.

Understanding this duality is essential for shaping the future of cybersecurity practice. Recent research provides empirical insight into the technical strengths and limitations of LLMs. Studies such as CTF-Know and CTFAgent illustrate how LLMs perform in structured solving environments, revealing strong baseline knowledge but inconsistent performance when models must apply that knowledge interactively. These findings help clarify how LLMs reason, where they fail, and how carefully designed frameworks can significantly improve their reliability in adversarial contexts.

At the same time, government agencies—including components of DHS such as CISA, ICE, HSI, and FEMA—have begun integrating LLM-driven tools into operational workflows. These deployments illustrate both the promise of AI-enhanced cybersecurity and the unique risks introduced when models shape national-security decision-making. Data exposure incidents, hallucination-driven misclassification, and vulnerabilities in the AI ecosystem underscore the need for strong oversight and technical guardrails.

The convergence of these trends has motivated a growing body of governance research. Frameworks from Korimilli et al. and Ahi et al. offer structured approaches to measuring, constraining, and regulating dual-use model behavior through tools such as prompt-intent classification, output sensitivity analysis, human-in-the-loop validation, and risk stratification metrics like the Dual-Use Risk Index (DURI).

This paper integrates these perspectives—technical capability, governmental application, and governance strategy—to examine how LLMs can be safely and effectively incorporated into cybersecurity operations. By synthesizing empirical findings and policy-oriented frameworks, we aim to clarify the key challenges and opportunities posed by LLMs and outline actionable paths toward responsible deployment.

LLMs and CTFs

In regard to large-language models and Capture-The-Flag challenges, the driving factor behind CTFs is global cybercrime. Cybercrime refers to any illegal internet-mediated activity that takes place in a global electronic network. These activities often impact confidentiality, integrity, and availability of data, such as phishing attacks. The global cost of cybercrime is \$10.5 trillion [Sal24], and it is expected to reach roughly \$20 trillion by 2030 [Sal24].

Because of the cost, it is imperative that individuals in the cybersecurity field engage in Capture-The-Flag challenges. CTFs will evolve to mimic the ever-changing cybersecurity landscape, so those in the field will learn, adapt, and help combat cybercrime. With the rise of large-language models, one may wonder the role they play in the continuous learning process: how well can LLMs perform CTFs?

There are two areas that need to be addressed. One, the aforementioned question of large language models’ performance in CTFs, and two, the positives and negatives of such performances on students in cybersecurity. In the past few years, there has been a rise of large

LLMs in everyday life; chatbots like ChatGPT utilize LLMs, and they're accessible to the general public. As such, knowing how well a LLM can do will give insights on student performance and academic integrity.

But before determining the effectiveness of large-language models in Capture-The-Flag challenges, it is important to measure LLMs technical knowledge. Getting a grasp on what a LLM knows about CTFs will guide the creation of a LLM framework that can best utilize the knowledge to actually solve challenges. This section will analyze research provided by Zimo Ji et. al.

CTFknow

CTFknow is a targeted benchmark designed by researchers specifically to test various LLMs' core technical knowledge [JWJ⁺25]. There were five phases when building CTF-Know:

1. Collection of writeups. From 700 Capture-The-Flag competitions, roughly 10,000 complete writeups were gathered. With the caveat of 30+ lines of text and no images/external links, 1084 "high-quality" writeups were filtered.
2. Extraction of CTF Knowledge. OpenAI GPT-4 was used to extract the understanding and exploiting steps of each writeup, resulting in various points of knowledge. Each point has three segments: the CTF's scenario, the exploit method, and an example payload. These segments ensures each instance of CTF knowledge maintains as much information integrity as possible. In the end, 2078 instances of CTF technical knowledge were extracted.

3. Knowledge Filtering. To mitigate hallucinations in large-language models, both the knowledge point and its corresponding writeup were input into Deepseek-chat-v2.5 for comparison; the point is retained if it fully matches the writeup and accurately reflected the content. 2013 knowledge points remained after filtering.
4. Question Generation. Single-choice and open-ended questions were generated, using both the original writeup and extracted knowledge as reference. The end result ensures the questions remain grounded and the LLM retains the CTF Scenario.
5. Question Filtering. Deepseek was used again.

1996 "high-quality" questions remained, which was subsequently manually verified for relevance to the original writeups and accuracy of single choice questions' answers.

CTFKnow Results

Five mainstream large-language models were measured against CTFKnow: GPT-3.5-Turbo, GPT-4-Turbo, GPT-4o, Llama-3-70b, and Mixtral-8x7b. In addition, five undergraduate students were tested on a random subset of questions, to help gain a more comprehensive understanding of LLM performance.

Single choice questions are akin to a multiple choice question in an exam, thus evaluating LLMs' correctness is straightforward. For open-ended questions, each question has a corresponding reference answer; a LLMs answer is considered correct if achieves the same effect as the reference answer without modifications (in other words, the LLM correctly matches technical knowledge to the CTF scenario).

Looking at the results for single-choice questions, it is clear: LLMs have a strong grasp of CTF technical knowledge. The overall accuracy for LLMs hovers around 70-80% [JWJ⁺25], with each individual CTF category having at least 70% accuracy [JWJ⁺25]; GPT-4o answered the most questions correctly, 1753 out of 1996 [JWJ⁺25]. For an individual category, the highest accuracy is GPT-4-Turbo in Reverse (90.62%) and the lowest is GPT-3.5-Turbo in Web (72.02%) [JWJ⁺25]. The undergraduates performed worse, their overall accuracy being 63.33% [JWJ⁺25].

When it comes to open-ended questions, LLMs performance noticeably worse. The overall accuracy of LLMs ranges from approximately 30-50% [JWJ⁺25], with the performance of undergraduates (32.66%) beating Mixtral-8x7b (30.66%) [JWJ⁺25]. These findings show that LLMs have poor capability in matching technical knowledge to CTF scenarios. Moreover, when comparing LLMs' correctness vs. open-ended question's difficulty, there is a visible decline.

The performance of LLMs in open-ended questions was higher than the proportion of CTF Challenges LLMs could solve in some previous studies (less than 30%) [JWJ⁺25]; the researchers suggest that the discrepancy is because the LLM lacked the right tools or failed to keep up with the CTF environment.

CTFAgent

Fundamentally, CTFAgent is a LLM-driven framework designed by the same researchers to solve CTFs [JWJ⁺25]. CTFAgent is augmented with two important modules address large-language models’ shortcomings in the previous section.

- Two-Stage RAG (Retrieval-Augmented Generation) System
 - All LLMs have RAG, but CTFAgent modifies it to have two parts.
 1. RAG-Understanding: Helps with identifying potential vulnerabilities.
 2. RAG-Exploiting: Helps with retrieving knowledge on how to exploit the potential vulnerabilities.
- Interactive Environmental Augmentation
 - Interactive Commands: The LLM is given enhancements to command-line tools (tool-use hints).
 - Advanced CTF Tools: CTFAgent is given a more powerful toolkit, including sophisticated code-auditing tools/code editors.

The Two-Stage RAG gives hints every step of the way; when presented with CTF challenge code, the RAG system will use its databases identify potential vulnerabilities (DB-Understanding) and how to exploit them (DB-Exploiting), repeating as the LLM advances.

CTFAgent Results

The evaluation of CTFAgent was split into two parts: its performance against benchmarks and humans. CTFAgent was tested against the Intercode and NYU-CTF benchmark on their respective data sets, which are designed to test CTFAgent’s cybersecurity capa-

bilities with actual Capture-The-Flags. Similar to what was seen in CTFKnow, CTFAgent is proficient in solving CTFs. When looking at the Intercode benchmark, CTFAgent has nearly double of CTFs solved (from 39% to 73%) [JWJ⁺25]. Despite still outperforming Intercode without augmented modules, the performance with the modules is noticeably greater. These traits persist for NYU-CTF, but the percentages are proportionally smaller [JWJ⁺25].

To determine CTFAgent’s performance against humans, CTFAgent performance was measured against 11,000 human teams in picoCTF 2024, a cybersecurity competition held by Carnegie Mellon University. With 19 out of 46 CTF challenges solved, CTFAgent amassed 1875 points, placing itself in the top 23.6% [JWJ⁺25]; this also significantly outperforms NYU-CTF, which placed in the top 47.2%. While CTFAgent performed just as good or better than human teams in most categories, it scored worse in Web and Pwn (Binary-Security) categories. One can interpret the results as highly encouraging, given how well CTFAgent outperforms benchmarks and humans.

Concerns and Benefits of LLMs in CTFs

The results of CTFAgent brings both positives and negatives. While CTFAgent is fully dedicated to solving CTFs, it is not improbable that any chatbots that utilize LLMs, like ChatGPT can achieve similar success with enough time. ChatGPT and other similar services have ethical safeguards meant to prevent misuse, yet it is vulnerable to jailbreaks. One particular jailbreak is Always-Intelligent-and-Machiaevellian (AIM), where the user prompts the chatbot to act like an author, sneakily bypassing safeguards.

This means that any student with internet access can freely access ChatGPT, enter in CTF details, and most likely get the correct solution; even if the student doesn't get the answer, they can upgrade to the paid version to get better responses (most chatbots do not require payment). Students can also trick chatbots into ignoring aforementioned ethical safeguards. The point is that students can rely on LLMs to solve Capture-the-Flags in homework assignments but they're not learning anything, which will not prepare them for the real world; even if chatbots are available, it will not keep up with the constantly-changing cybersecurity landscape. Using LLMs to solve homework assignments also violates academic integrity, since it is not the student's work. There's also the issue with CTFAgent itself. The power of CTFAgent raises concerns on how prevent misuse of it, and if its within ethical standards.

With the right oversight, large-language models can be used as an aid in solving capture-the-flags; it would be similiar to the Two-Stage RAG, explaining vulnerabilities and suggesting technical concepts. Because the LLM would lead students in the right direction without providing a direct solution, the student actually learns, and academic integrity is not violated. LLMs could also augment CTF competitions; LLMs could create CTFs with greater educational significance, and also judge the competition. The end result would be less burden placed on the organizers and a more competitive competition. The more competitive it is, the more cybersecurity knowledge participants end up learning.

As for CTFAgent concerns, the researchers that developed it have concluded that risk is mitigated [JWJ⁺25]. 1.) CTFAgent is not publicly available, and it must be requested to use. 2.) The data used to construct CTFAgent is publicly available. 3.) It is only used in

isolated CTF environments. 4.) It immediately ceases operations after capturing the flag.

There are other neural networks that are touching upon the aforementioned positives [JWJ⁺25]. AutoPwn assists with CTF solving progress. Pwnable-Sherpa is a coaching system trying to enhance the educational significance of CTF challenges. AutoCTF is focusing on CTF challenge design. Ultimately, CTFAgent and other LLMs are heading in a direction that assists individuals in fighting cybercrime without taking over.

Governmental Usage

Dual-Usage Challenge and need for Governance

Large Language Models (LLMs) have become deeply embedded in modern cybersecurity operations, providing transformative capabilities for defenders while simultaneously expanding the arsenal available to adversaries. This inherent dual-use nature - where the same model can detect a malware family or help generate one - creates a fundamental governance challenge. As organizations adopt LLMs for security automation, they must also address the reality that attackers, including low-skilled adversaries, can exploit the same models to scale harmful activity. This section analyzes why LLM duality requires a structured governance response and synthesizes governance frameworks proposed in key recent literature, including the Journal of Information Systems Engineering and Management (JISEM) study by Korimilli et. al., and the TechRxiv survey by Ahi et al.

Inherent Duality in LLM Cyber Capabilities

LLM dual-use risk arises directly from the architecture and training regime of large transformer models. Because LLMs capture statistical relationships in both natural language and code, their reasoning capabilities generalize to a broad set of tasks, including those used in cybersecurity operations. This means the same cognitive patterns used to analyze vulnerabilities or summarize system logs can also be used to generate exploit chains, obfuscate malware, or create highly targeted phishing content.

Recent evaluations underscore this duality. The JISEM study demonstrates that contemporary LLMs significantly enhance defensive workflows, achieving **91% SOC intrusion classification accuracy** and reducing triage time by **40–50 seconds per alert** through automated summarization and correlation of security events [SKK25]. Yet the same study reveals that models such as GPT-3.5 can be used offensively: it generated phishing content with an **87% detection bypass rate** and received a **4.5/5 realism rating** from human evaluators, enabling attackers to create highly convincing social engineering campaigns at scale [SKK25].

Similarly, the TechRxiv survey (Ahi et al.) documents a rapidly expanding ecosystem of *malicious LLMs*—including WormGPT, FraudGPT, and DarkBERT—purpose-built for generating polymorphic malware, crafting Business Email Compromise payloads, and producing obfuscated attack code [KA25]. These models replicate the architecture of commercial LLMs but remove or bypass safety constraints, illustrating the ease with which offensive applications can proliferate once model weights circulate.

The CyBench evaluation further highlights LLM duality by demonstrating that frontier models can autonomously solve complex cybersecurity tasks. Models such as GPT-4o and Claude 3.5 Sonnet were able to perform exploit reasoning, reverse engineering, and multi-step vulnerability analysis—solving professional-grade CTF tasks with increasingly sophisticated reasoning sequences [ea25]. Notably, models showed strong performance on tasks requiring offensive understanding, such as constructing exploits or analyzing vulnerable source code, reinforcing that capability growth benefits both defenders and attackers.

This combination of high defensive value and high offensive potential illustrates why dual-use risk is intrinsic to LLM development and not a byproduct of poor deployment practices. As models continue to scale, their utility and risk will escalate in parallel, requiring governance measures that directly address this symmetry.

Why Dual-Use Necessitates Robust Governance

Several factors drive the urgency of governance for dual-use LLMs.

Asymmetric Accessibility

Defensive applications of LLMs require substantial infrastructure for secure deployment, continuous monitoring, and alignment tuning. Offensive use requires virtually nothing beyond *model access*. As the TechRxiv authors emphasize, adversaries “only need an API endpoint or leaked weights,” making offensive usage dramatically easier than defensive integration [KA25].

Capability Growth Outpacing Regulatory Speed

AI development cycles operate on a scale of months, whereas regulatory frameworks evolve over years. The CyBench report shows LLM capabilities increasing rapidly: new model releases solved harder CTF tasks, generated more coherent exploit chains, and demonstrated more reliable multi-step reasoning with each iteration [ea25]. Without proactive governance, capability escalations will outstrip regulatory safeguards.

Proliferation of Open-Weight Models

Once a powerful LLM is released open-source, governance becomes essentially impossible. Ahi et al. emphasize that open weights facilitate *malicious fine-tuning*, distribute harmful capabilities globally, and enable attackers to permanently bypass safety layers removed during fine-tuning or model editing [KA25].

Architectural Lack of Intent-Awareness

LLMs lack the ability to differentiate benign from malicious intent. Safety layers are external patches, not inherent capabilities. The JISEM study shows a **64% jailbreak success rate**, meaning safety mechanisms can be circumvented with surprisingly simple adversarial prompts [SKK25]. Governance must therefore compensate for architectures incapable of reliably self-regulating harmful outputs.

These challenges make governance not optional but necessary for safe LLM evolution.

Governance-by-Design: Operational Frameworks for Managing Dual-Use

Effective governance must operate across the entire lifecycle of LLM development, deployment, and use. Both the JISEM and TechRxiv papers provide detailed governance frameworks that organizations can apply.

Governance Mechanisms from the JISEM Framework

The JISEM article proposes an “*operational governance model*” built around measurable, integrated controls:

- **Dual-Use Risk Index (DURI):** A real-time scoring mechanism that evaluates prompts and outputs for malicious indicators such as exploit writing or obfuscation [SKK25].
- **Prompt Intent Classification:** Classifies user prompts into benign, ambiguous, or malicious and applies appropriate gating [SKK25].
- **Output Sensitivity Analysis:** Detects harmful code or exploit patterns before output is delivered [SKK25].
- **Human-in-the-Loop:** High-risk LLM actions require explicit human approval [SKK25].
- **Watermarking & Provenance:** Embeds identifiers in model outputs for forensic traceability [SKK25].
- **Lifecycle Auditing:** Continuous evaluation and monitoring of model behavior and risk [SKK25].

Multi-Level Governance Strategies from the TechRxiv Paper

Ahi et al. propose a comprehensive multi-stakeholder model:

Policymakers

- Mandatory red-teaming for high-risk models
- Capability-based risk classification
- Required incident reporting for LLM misuse
- Transparency and traceability standards for datasets and training pipelines

Security Organizations

- Role-Based Access Control (RBAC) for sensitive model features
- Sandboxing generated code or exploit logic
- Monitoring usage patterns for anomalous or malicious activity
- Restricting fine-tuning datasets to prevent injection of malicious training samples

LLM Developers

- Safety-aligned decoding methods and constrained generation
- Adversarial prompt hardening and jailbreak resistance
- Modular capability access with per-function gating
- Staged release strategies (API-first, delayed weight release)
- Watermarked training pipelines and output provenance

This multi-level strategy distributes governance responsibility across all stakeholders—reducing the likelihood of harmful capability leakage.

Integrating Governance with Innovation

The goal of dual-use governance is not to suppress innovation but to guide it responsibly. As LLMs increasingly underpin both defensive and adversarial operations, regulatory strategies must scale alongside technological advancement. This includes:

- Proactive capability benchmarking (e.g., CyBench) [ea25]
- Continuous monitoring of deployed models
- Cross-sector collaboration between industry, government, and academia
- Controlled access to high-risk capabilities through API gating
- Mandatory adversarial testing prior to deployment

By integrating governance throughout the AI lifecycle, organizations can mitigate dual-use risks while preserving the transformative potential of LLMs in cybersecurity.

Why Government Use of LLMs Matters

Large Language Models (LLMs) are becoming integrated into critical federal operations, especially within agencies responsible for national security and cybersecurity. When LLMs are deployed inside the Department of Homeland Security (DHS), their influence extends beyond efficiency gains—they directly affect decisions related to national safety, cyber threat response, and emergency management. Federal agencies routinely handle sensitive and high-stakes data, meaning that any malfunction, misuse, or vulnerability introduced by AI tools carries the potential for serious real-world consequences. Understanding how DHS uses LLMs provides a concrete example of operational AI adoption in the U.S. government and highlights why secure governance and oversight are essential.

How DHS Uses LLMs for Cybersecurity and Operations

The DHS AI Use Case Inventory documents dozens of approved AI and LLM applications across DHS components, including CISA, CBP, ICE, TSA, USCIS, and FEMA [U.S25]. These use cases show that the federal government is already relying on advanced AI systems for many essential tasks.

Text Generation and Document Support

DHS employees are permitted to use commercial generative AI systems to produce draft documents, research summaries, briefing materials, and meeting preparation content [U.S25]. These applications use LLMs to improve workflow efficiency, while retaining human oversight to ensure accuracy and compliance.

Cybersecurity Operations at CISA

CISA has begun integrating LLM- and NLP-driven tools into cybersecurity operations, particularly for handling large quantities of unstructured text found in cyber threat submissions. Several operational workflows rely on LLM-adjacent capabilities such as automated summarization, semantic understanding, and natural-language classification [U.S25]. For example, NLP systems assist analysts by identifying possible PII in threat indicators, extracting entities, and prioritizing information for human review.

CISA's incident reporting and vulnerability analysis processes also use text analytics models to filter, categorize, and summarize incoming data, enabling analysts to focus on the most relevant threats. These systems help manage overwhelming volumes of threat intelligence by reducing manual triage time while preserving expert judgment.

Investigative and Forensic Tools

Homeland Security Investigations (HSI) employs several AI-enhanced investigative tools that incorporate LLM capabilities for searching, summarizing, and correlating large datasets. The HSI Semantic Search and Summarization system exemplifies this trend by using LLM-based techniques to scan investigative reports, extract relevant insights, and identify relationships between entities, significantly reducing the time required for manual review [U.S25]. These tools strengthen investigative workflows, improve evidence analysis, and support the identification of criminal networks.

FEMA's Generative AI Tools

FEMA has adopted LLM-driven systems to improve internal operations and provide support to state and local governments. FEMA OCFO GPT is a generative AI system designed to answer budget-related questions and produce draft responses for human validation. Similarly, the Planning Assistant for Resilient Communities (PARC) uses LLM capabilities to generate draft hazard mitigation plan elements and assist communities in understanding risk information [U.S25]. These examples illustrate how LLMs contribute not only to cybersecurity efforts but also to administrative efficiency and public-sector service delivery.

Risks of DHS and Government Use of LLMs

Despite their advantages, integrating LLMs into federal operations introduces several significant risks that require careful governance and mitigation. One major concern is false confidence and hallucinations. LLMs may produce information that appears credible but is

factually incorrect or entirely fabricated. In national security environments, such errors can mislead analysts, distort reports, or influence operational decisions.

Another concern is privacy and sensitive data exposure. When LLMs process sensitive operational data, there is a risk that the system may reveal internal identifiers, private information, or protected data in its output. Although DHS employs automated PII detection tools [U.S25], the fundamental vulnerability persists because LLMs generate text based on patterns learned from the data they process.

LLMs also create risks in mission-critical, high-stakes environments. Errors in cyber incident reporting or vulnerability classification could delay critical responses, obscure emerging threats, or produce inaccurate early-warning signals. Given DHS's national security mission, these mistakes carry consequences far beyond those of typical civilian AI deployments.

Finally, LLMs pose an inherent dual-use challenge. The same capabilities that strengthen defensive cybersecurity operations can also be exploited by adversaries. Malicious actors may use LLMs to craft convincing phishing messages, automate reconnaissance, write malware, or analyze stolen datasets at scale. As DHS becomes more dependent on LLM-driven workflows, attackers can replicate similar tools, amplifying the broader threat landscape.

Real-World Incidents Showing AI-Related Data Exposure

Recent incidents from 2024–2025 reveal how AI-related systems and the infrastructure surrounding them can become significant points of vulnerability. In May 2024, an AI firm with ties to U.S. government agencies exposed more than a billion documents after leaving a cloud server publicly accessible without authentication [McC24]. This breach demonstrates

how AI system deployment can increase the impact of operational failures: a single misconfiguration enabled unrestricted access to sensitive internal files, highlighting the scale of risk associated with AI-driven organizations.

A second major incident occurred in late 2024 when Mixpanel, a commercial analytics provider used by OpenAI, was compromised in a cyberattack. The attacker accessed internal usage logs and data associated with ChatGPT [Dav25]. This event illustrated how third-party dependencies can expose sensitive information, especially when AI systems rely on external analytics platforms or cloud-based processing. For government agencies that leverage commercial AI tools, similar vulnerabilities could lead to the exposure of protected or operationally sensitive data. Combined, these incidents show that AI ecosystems—particularly those involving cloud services and external vendors—carry real risks of unintended data exposure.

Summary of Key Takeaways

LLMs provide DHS with powerful capabilities for cybersecurity, investigations, and administrative analysis. While these tools meaningfully enhance efficiency and strengthen analytic capacity, they also introduce substantial risks related to data exposure, accuracy, and adversarial misuse. Recent AI-related data leaks demonstrate that even trusted AI contractors and major commercial vendors can become points of failure in an AI-driven ecosystem. DHS's operational environment highlights the high stakes involved, where AI errors or vulnerabilities may have national-level consequences. Strong governance frameworks, continuous oversight, and secure deployment practices are essential to ensure that LLMs enhance federal operations safely, responsibly, and effectively.

Conclusions

This paper brought together three perspectives on LLMs in cybersecurity: how well they perform in CTF environments, how government agencies like DHS are using them, and why their dual-use nature makes governance so important. From the technical side, we saw that LLMs can answer many CTF knowledge questions and even solve real challenges when supported with tools like CTFAgent. At the same time this raises concerns about misuse, academic integrity, and how easily these models can also support offensive tasks. Our look at DHS showed that LLMs are already being used in real operations—from cybersecurity analysis to investigations and disaster planning. These deployments demonstrate clear benefits, but they also come with risks such as hallucinations, privacy issues, and data exposure, which recent incidents in the AI system have made very clear.

Finally, the governance research we reviewed shows that LLMs need structured oversight because they can help defenders and attackers equally. Techniques like intent detection, output filtering, human review, and risk scoring offer ways to manage these challenges. Overall, LLMs will continue to shape cybersecurity in powerful ways, but their benefits depend on careful deployment and strong governance. With the right safeguards, they can enhance security rather than create new vulnerabilities.

Discussion

The findings across the technical, operational, and governance analyses in this paper highlight several themes central to the future of cybersecurity in the post-LLM era. First, empirical studies show that LLMs possess strong foundational knowledge of cybersecurity concepts, particularly when evaluated through structured benchmarks such as CTF-Know.

Their performance improves dramatically when augmented with retrieval systems, tool-use scaffolding, or multi-stage agentic workflows, as seen in CTFAgent. This suggests that raw model capability is only one component of cybersecurity performance: architecture, orchestration, and environmental integration are equally important determinants of success. However, these augmentations also raise the risk ceiling by making offensive tasks more accessible, especially when similar techniques are employed by malicious actors. Several broader implications emerge from this synthesis. LLMs are not merely tools; they are rapidly becoming infrastructure in both cyber offense and defense. Their widespread accessibility transforms the strategic landscape by reducing attacker resource requirements while increasing defender analytical capacity. This expanding symmetry requires new forms of collaboration between researchers, policymakers, and security practitioners. Furthermore, as LLMs begin to interface directly with critical systems—log pipelines, investigation tools, autonomous agents—failures can propagate faster and more broadly than with traditional software.

Finally, the paper raises multiple avenues for future research:

- How can LLMs be designed to inherently resist malicious prompting rather than relying on external filters?
- What metrics can meaningfully capture dual-use risk across diverse operational contexts?
- How should governance frameworks evolve as LLMs become multimodal, agentic, and increasingly autonomous?
- What organizational structures and skill sets will future SOC's require as AI-human collaboration becomes more tightly integrated?

While LLMs introduce considerable uncertainty, they also offer unprecedented opportunity. The challenge ahead lies in shaping their development and deployment so that the benefits dominate the risks—a task requiring not only technical ingenuity but also policy innovation, interdisciplinary governance, and a shared societal commitment to secure and ethical AI.

References

- [Dav25] James Davis. Hackers stole data from openai’s analytics partner mixpanel. *Business Insider*, November 2025.
- [ea25] Andy K. Zhang et. al. Cybench: A framework for evaluating cybersecurity capabilities and risks of language models. *ICLR*, 2025.
- [JWJ⁺25] Zimo Ji, Daoyuan Wu, Wenyuan Jiang, Pingchuan Ma, Zongjie Li, and Shuai Wang. Measuring and augmenting large language models for solving capture-the-flag challenges, 2025.
- [KA25] Vaibhav Agrawal² Saeed Valizadeh³ Kiarash Ahi¹, 4. Dual-use of large language models (llms) and generative ai (genai) in cybersecurity: Risks, defenses, and governance strategies. *TechRxiv*, 2025.
- [McC24] Joel R. McConvey. Ai firm with ties to u.s. government exposes billions of documents in breach. *BiometricUpdate*, May 2024.
- [Sal24] Katy Salgado. Global cybercrime report 2025, Dec 2024.
- [SKK25] Goutham Sunkara³ Mohammad Mushfiqul Haque Mukit⁴ Abdullah Al Hasib⁵ Sridhar Krishna Korimilli¹, Md Habibur Rahman². Dual-use of generative ai in cybersecurity: Balancing offensive threats and defensive capabilities in the post-llm era. *Information Systems Engineering and Management*, 2025.
- [U.S25] U.S. Department of Homeland Security. Ai use case inventory. Technical report, U.S. Department of Homeland Security, 2025.